

SecCheck 관리자 운영 가이드 (Admin Guide)

SecCheck 는 오프라인 폐쇄망 및 엔터프라이즈 환경에서 외부 의존성 없이 안정적으로 동작하도록 설계된 보안 검토 플랫폼입니다.

1. 런타임 환경변수 4종

서비스 구동 시 필요한 환경변수는 정확히 다음 4개뿐이며, 그 외 모든 정책은 관리자 웹 콘솔에서 런타임으로 관리됩니다:

환경변수명	필수 여부	설명	예시
POSTGRES_DSN	필수	PostgreSQL 연결 DSN (<code>sslmode=verify-full</code> 권장)	<code>postgres://seccheck:pass@postgres:5432/seccheck?sslmode=disable</code>
BOOTSTRAP_ADMIN	필수	초기 로컬 관리자 아이디	<code>admin</code>
BOOTSTRAP_ADMIN_PASSWORD	필수	초기 관리자 비밀번호 (최소 12자 이상)	<code>ComplexPassword123!</code>
ENCRYPTION_KEY	필수	비밀값 및 데이터 키 암호화용 32바이트 Master Key	<code>01234567890123456789012345678901</code>

2. Keycloak OIDC SSO 엔터프라이즈 연동

SecCheck 는 표준 OpenID Connect Discovery를 통해 사내 Keycloak과 원클릭으로 연동됩니다.

1. Keycloak Client 설정:

- Client Type: `OpenID Connect`
- Client Authentication: `ON` (Confidential)
- Standard Flow: `ON`
- Valid Redirect URIs: `https://<seccheck-host>/api/v1/auth/oidc/callback`

2. 관리자 콘솔 설정 (`/admin/settings` → `Keycloak OIDC`):

- Keycloak / OIDC SSO 활성화 `ON`
- Issuer URL: `https://keycloak.company.internal/realms/enterprise`
- Client ID & Client Secret: Keycloak 발급 자격증명 입력 (AES-256-GCM 암호화 보관)

- **Callback URL:** `https://seccheck.company.internal/api/v1/auth/oidc/callback`
- 사용자명 **Claim:** `preferred_username`
- 기본 역할: `REQUESTER`

3. 연결 테스트:

- **Discovery 연결 테스트** 버튼을 클릭하여 엔드포인트 도달 가능 여부를 실시간 검증합니다.

3. RBAC 7대 역할 체계

역할 코드	한글 명칭	권한 범위
<code>SYSTEM_ADMIN</code>	시스템 관리자	서비스 설정, 사용자 및 역할 관리, 감사로그 열람 및 체인 검증
<code>TEMPLATE_ADMIN</code>	체크리스트 관리자	템플릿 생성/편집/게시, Security Control 등록, Excel 가져오기
<code>SECURITY_REVIEWER</code>	보안 담당자	보안 검토 Queue 조회, 검토 시작, 판정, 보완 요청 및 검증 완료
<code>APPROVER</code>	승인자	최종 승인 및 반려 의사결정 권한
<code>REQUESTER</code>	심의 요청자	신규 심의 생성, 체크리스트 작성, 증적 업로드, 제출 및 재제출
<code>CONTRIBUTOR</code>	공동 작성자	배정된 심의의 체크리스트 공동 작성 및 증적 첨부
<code>AUDITOR</code>	감사자	모든 심의 및 감사로그 읽기 전용 열람 권한

4. 파일 업로드 보안 & ClamAV 안티바이러스

- **Magic/MIME & 확장자 교차 검증:** 파일 확장자 위변조(예: `.exe` 를 `.pdf` 로 변경)를 서버 레벨에서 차단합니다.
- **AES-256-GCM 암호화 보관:** 모든 증적은 서버 디스크에 UUID 파일명으로 암호화되어 저장됩니다.
- **ClamAV 악성코드 검사:**
 - 관리자 설정에서 **ClamAV 악성코드 검사** 활성화 및 `clamav:3310` 데몬 주소 입력
 - ClamAV 검사 실패 또는 악성코드 탐지 시 파일 업로드는 즉시 차단(Fail-Closed)됩니다.

5. 암호학적 해시 체인 감사로그 무결성 검증

- **해시 체인 구조:**
 - 모든 행위(로그인, 심의 생성, 수정, 제출, 판정, 승인, 설정 변경, 키 회전)는 이전 이벤트의 해시(`prev_hash`)와 결합되어 SHA-256 해시 체인을 형성합니다.
 - 데이터베이스 직접 조작이나 위변조가 발생할 경우 체인이 즉시 깨집니다.
- **체인 검증 실행 (`/admin/audit`):**
 - **체인 검증** 버튼을 누르면 서버가 전체 이벤트의 암호학적 링크를 전수 검사하여 **"N개 감사 이벤트의 해시 체인이 유효합니다."** 결과를 반환합니다.

6. 관측성 및 Prometheus 모니터링

엔드포인트	메서드	용도	설명
/health	GET	Liveness Probe	프로세스 생존 여부 확인
/ready	GET	Readiness Probe	DB 풀 및 테이블 쿼리 가능 상태 확인
/metrics	GET	Prometheus Metrics	API 요청수, 지연시간, 심의 상태별 통계, 증적 저장량, 실패 작업 수 수집
/mcp	POST	Model Context Protocol	AI 에이전트 연계 인터페이스 (2026-07-28)